

CYBERSOC · DIGITAL FORENSICS & INCIDENT RESPONSE

Deep Forensic Investigation

Incident **81192** — AiTM Credential Phishing → Session Hijack → AI Resource Abuse → OAuth Persistence

INCIDENT ID	SEVERITY	STATUS	PRIMARY VICTIM	
81192	High (priorityScore 100)	Active	Elvia Atkins · elviaa@zava-corp.com	
TENANT	DETECTED	REPORT DATE	CLASSIFICATION	
zava-corp.com (0527ecb7...)	2026-05-22 02:53 UTC	2026-06-08	Confirmed True Positive	

1. Executive Summary

On **22 May 2026**, the user **Elvia Atkins** (elviaa@zava-corp.com, tagged *Critical asset*) was compromised through an **Adversary-in-the-Middle (AiTM) phishing** campaign. A lure email impersonating a system-outage alert was delivered to her Inbox at 01:57:53 UTC, after an earlier copy was quarantined. The user clicked the embedded AiTM link **seven times** between 02:15 and 02:44; the proxy harvested her credentials **and session cookie**, defeating MFA. Within minutes the attacker signed in from **known AiTM / Tor infrastructure** and Microsoft **Attack Disruption** auto-revoked her tokens and disabled the account.

The intrusion is notable for its **AI-centric objectives**. After hijacking the session the actor abused **Microsoft 365 Copilot** and an **Azure OpenAI** resource (mdc-d4ai-aoai-1, model gpt-4o): LLM reconnaissance, jailbreak attempts (blocked by Prompt Shields), a malicious-URL injection in a prompt, and DLP-protected content access. The actor then established **standalone persistence** by registering an OAuth application (**AI-Sys-AutoNinja**), adding client secrets and granting consent — access that **survives a password reset**.

Critical finding — persistence likely still live

An analyst **re-enabled the account at 03:09 UTC** ("I fixed the cause and re-enabled her account"), but the attacker-controlled OAuth app **AI-Sys-AutoNinja** (8cfa5715-1f9e-4d2f-8c5b-81a59c37cd80) was consented at 04:15 and was **not** remediated. Two containment playbooks also **failed** (Block-EntralDUser: token expired; AWSIAM-DeleteAccessKeys: failed x2). **The environment should be treated as still exposed until the app and its secrets are revoked.**

16+

CORRELATED ALERTS

5

ACTIVE TI-CONFIRMED IPS

7

AITM URL CLICKS

3

CLOUD TRUSTS IN BLAST
RADIUS

Confirmed impact

- Credential + session-cookie theft (MFA bypass via AiTM).
- Interactive sign-in from TI-confirmed Tor/AiTM IPs.
- Abuse of M365 Copilot and Azure OpenAI gpt-4o (LLM recon, jailbreak attempts, malicious-URL prompt).
- DLP-labelled content reached; OneDrive sharing inheritance broken.
- OAuth app persistence (AI-Sys-AutoNinja) with consent + secrets.

Immediate priorities

- **Revoke / delete** app AI-Sys-AutoNinja + all its credentials.
- **Re-revoke** Elvia's sessions; reset password again post-app removal.
- Re-run failed containment (Entra block, AWS key deletion).
- Hunt the 5 IOC IPs + AiTM domain across the estate.
- Review AWS / GCP / GSOC federation for lateral reach.

Environment note: this tenant is an **AI attack-simulation lab** (incident tags Agent Simu ; title prefix "AI simulation"). Baseline sign-in telemetry is unusually Tor-heavy, so geo-anomaly scoring is calibrated against that baseline. The intrusion itself is a genuine, high-severity true positive.

2. Identity Profile — Elvia Atkins

Display name	Elvia Atkins
UPN	elviaa@zava-corp.com
Entra object ID	befd56cb-ba43-4f04-a630-252ee3870c7f
On-prem SID	S-1-5-21-4059190129-3803843963-274501666-1111
Asset tag	CRITICAL ASSET
Investigation verdict	MALICIOUS / COMPROMISED

Federation & reach

Audit-log provisioning sync shows the identity projecting into multiple downstream trusts — the practical blast radius of this account:

- Zava to Zava GSOC cross-org GSOC federation
- AWS Federated Access SAML/role federation to AWS
- Google Cloud GCP federation

A failed AWSIAM-DeleteAccessKeys playbook confirms the account maps to live AWS IAM credentials.

Why this identity matters

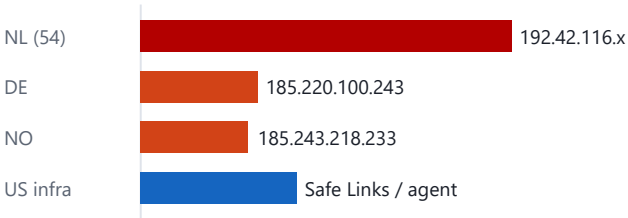
Elvia is a **critical asset** whose identity federates into **AWS and GCP** as well as a cross-org GSOC tenant. A single credential/session theft therefore carries **multi-cloud** lateral-movement potential, which is why Attack Disruption auto-contained within ~6 minutes of the malicious sign-in.

3. Sign-In Analysis with Geolocation (365 days)

Sign-in and Copilot/cloud telemetry over the trailing 365 days, with the attack window isolated. Locations derived from MDTI enrichment and IP geolocation. "Lab baseline" rows are pre-existing simulation noise, not part of this intrusion.

IP ADDRESS	GEOLOCATION	TYPE	WINDOW	ACTIVITY	ASSESSMENT
192.42.116.56	Amsterdam, NL	Tor exit / AiTM	22 May 02:47-02:57	Risky sign-in, M365 Copilot, 24 events	ATTACKER
2001:67c:e60:c0c:192:42:116:113	Camperduin, NL	Tor exit (IPv6)	22 May 03:20-03:30	M365 Copilot, 30+ events	ATTACKER
192.42.116.55	Amsterdam, NL	Tor exit / AiTM	22 May (AI window)	Azure OpenAI access	ATTACKER
185.220.100.243	Hassfurt, DE	Tor exit	22 May (AI window)	Azure OpenAI access	ATTACKER
185.243.218.233	Sandefjord, NO	Tor exit	22 May (AI window)	Azure OpenAI access	ATTACKER
185.241.208.136	Europe (Tor)	Tor exit	22 May	TOR sign-in activity	ATTACKER
20.42.219.201	Azure (US)	MS Safe Links / detonation	22 May 02:15-02:44	UrlClick detonation of AiTM link	BENIGN INFRA
4.176.x.x / 4.251.25.106	Azure	Agent infra	22 May	InvokeAgent / InferenceCall	AI AGENT
185.220.0.0/16 (various)	EU Tor exits	Tor	Trailing 365d	Recurring sign-ins	LAB BASELINE
74.235.241.47	United States	Automation	Trailing 365d	7,392 failed ("UDS user automation")	LAB NOISE

Geographic clustering (attack window)



Attacker activity clusters across **NL, DE, NO** Tor exits — consistent with a single operator rotating exit nodes, not geographically distributed users.

Behavioural read

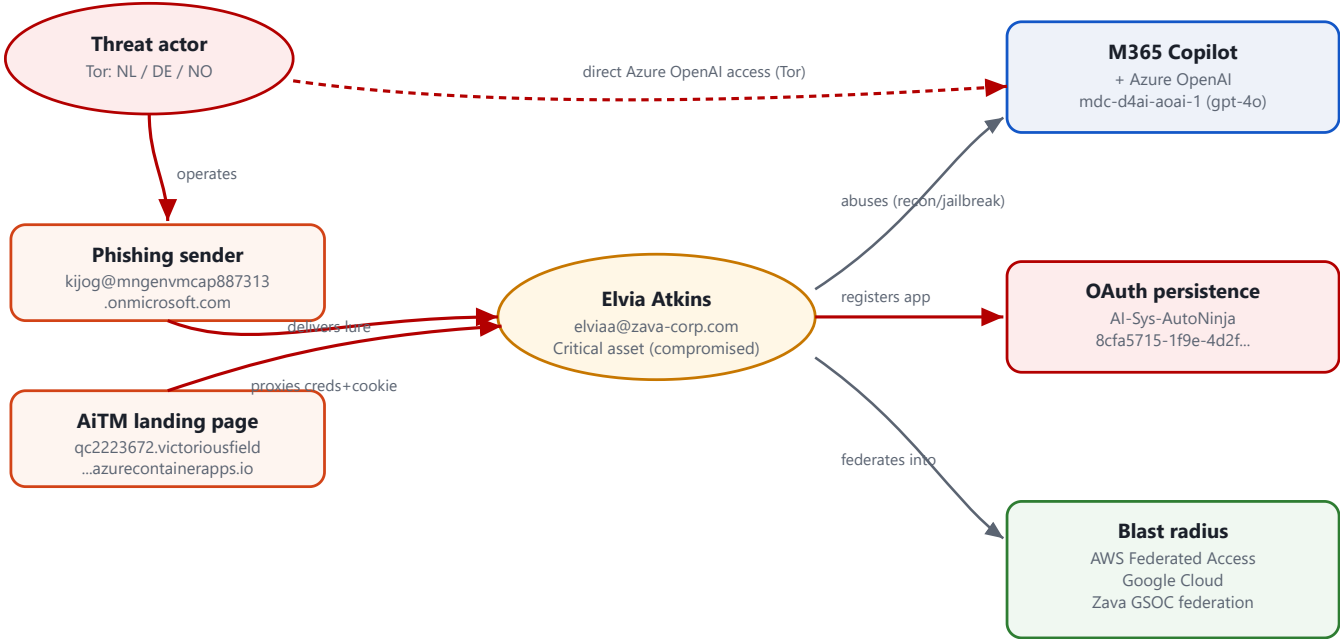
- **Impossible travel** is muted by the Tor baseline, but the **burst pattern** (24 Copilot events in 8 min, then 30 in 10 min) is machine-paced, not human.
- Sign-in client **M365ChatClient** dominates — activity is driving **Copilot**, not normal Office work.
- Edge 148 / Windows 10 user-agent on the risky sign-in matches the stolen-session fingerprint.
- Separate **Azure OpenAI** access from 192.42.116.55 / 185.220.100.243 / 185.243.218.233 indicates parallel tooling.

4. Event Timeline (22 May 2026, UTC)

-  **01:31:16 · Phishing email #1 (quarantined)**
Sender kijog@mngenvmcap887313.onmicrosoft.com, subj "[URGENT] [System Name] Outage". Junked. (IPv6 2a01:111:f403:c111::5)
-  **01:57:53 · Phishing email #2 DELIVERED to Inbox**
Patient-zero message. Same subject, 3 URLs, networkMessageId e80ef13c-6fe8-4eb3-8243-08deb7a57454. (IPv6 2a01:111:f403:c105::1)
-  **02:15-02:44 · AiTM link clicked x7 (ClickAllowed)**
User clicks qc2223672.victoriousfield-3d105967.northeurope.azurecontainerapps.io at 02:15, 02:18, 02:22, 02:27, 02:31, 02:38, 02:44. Safe Links verdict: **Allowed**. Credentials + cookie proxied.
-  **02:21-02:38 · Follow-up lures delivered**
"Monthly Expense Report - Approval Deadline" x3 delivered to Inbox (reinforcement).
-  **~02:47 · Risky sign-in after AiTM (Attack Disruption trigger)**
Sign-in from 192.42.116.56 (Amsterdam Tor). Session 004fae8a-800d-8b3c-4b8a-18e30fc43385, Edge 148/Win10. Detected by 3 detectors (T1557, T1539, T1598).
-  **02:49-02:57 · M365 Copilot abuse begins**
24 CopilotInteraction events from 192.42.116.56. Possible jailbreak during Copilot interaction (T1562, T1213).
-  **02:53:04 · Incident 81192 raised (High)**
"AI simulation + User compromised by known AiTM phishing kit (attack disruption)".
-  **02:54:04 · Token revoke (Attack Disruption)**
"Update StsRefreshTokenValidFrom Timestamp" — refresh tokens invalidated automatically.
-  **02:55:00 · Account auto-disabled**
"Disable account" by Attack Disruption.
-  **03:20-03:30 · Continued Copilot abuse (IPv6 Tor)**
30+ CopilotInteraction events from 2001:67c:e60:c0c:192:42:116:113 (Camperduin).
-  **03:09:34 · Analyst RE-ENABLES account**
"Enable account" + comment: *"I confirmed Elvia was compromised by phishing link. I fixed the cause and re-enabled her account!!"* — **premature; persistence not yet removed.**
-  **~03:29-04:05 · Azure OpenAI abuse**
"Azure AI resources accessed by anonymized IP" on mdc-d4ai-aoai-1 (gpt-4o) from 192.42.116.55 / 185.220.100.243 / 185.243.218.233. LLM Reconnaissance; phishing-URL injected in prompt (<http://absoluteprintgroup.com/track>); Jailbreak blocked by Prompt Shields.
-  **04:10:10 - 04:15:32 · OAuth persistence established**
App **AI-Sys-AutoNinja** registered (04:10:10) → client secret created → service principal added (04:10:11) → updated/2nd secret (04:15:18) → **consent granted (04:15:32)** for appld 8cfa5715-1f9e-4d2f-8c5b-81a59c37cd80. (T1098)
-  **Later · Containment playbooks FAILED**
Block-EntraIDUser (token expired); AWSIAM-DeleteAccessKeys (failed x2). Gaps remain open.

5. Organizational & Attack Relationship Graph

Attack-path view linking the threat actor, delivery infrastructure, the compromised identity, abused AI resources, persistence, and the federated blast radius. The MCP exposure-graph walk returned **no pre-computed walkable paths** for this identity (the lab exposure graph is not populated), so the graph below is reconstructed from the correlated telemetry.



EDGE	EVIDENCE	TECHNIQUE
Actor → Phishing sender	5 lures from kijog@mngenvmcap887313.onmicrosoft.com	T1566.002
Sender → Elvia (delivered)	networkMessageId e80ef13c-... at 01:57:53	T1566
AiTM page → Elvia	7 ClickAllowed events; session cookie theft	T1557, T1539
Elvia → AI resources	CopilotInteraction x54, Azure OpenAI access	T1213, LLM abuse
Elvia → OAuth app	AI-Sys-AutoNinja consent 04:15:32	T1098
Elvia → Federation	Provisioning sync to AWS / GCP / GSOC	T1078.004

6. AuditLog Evidence

6.1 Containment & remediation actions

TIME (UTC)	OPERATION	ACTOR	INTERPRETATION
02:54:04	Update StsRefreshTokenValidFrom Timestamp	Attack Disruption	Auto token revoke
02:55:00	Disable account	Attack Disruption	Auto containment
03:09:34	Enable account	Analyst	Premature re-enable
–	Security-info registrations	u153@a.alpineskihouse.co (13.71.146.83)	SOC admin remediation
–	Provisioning sync	System	Zava GSOC / AWS / GCP federation

6.2 OAuth application persistence (AI-Sys-AutoNinja)

TIME (UTC)	OPERATION	TARGET	ACTOR
04:10:10	Add application	AI-Sys-AutoNinja	Elvia Atkins (hijacked)
04:10:10	Create application – Certificates & secrets	AI-Sys-AutoNinja (secret #1)	Elvia Atkins
04:10:11	Add service principal	AI-Sys-AutoNinja SP	Elvia Atkins
04:13:10	Update service principal / Update application	AI-Sys-AutoNinja	Elvia Atkins
04:15:18	Update Certificates & secrets	AI-Sys-AutoNinja (secret #2)	Elvia Atkins
04:15:32	Consent to application	appld 8cfa5715-1f9e-4d2f-8c5b-81a59c37cd80	Elvia Atkins

Persistence survives password reset

The OAuth app holds its **own client secrets** and a granted **consent**. It will continue to authenticate as a service principal even after Elvia's password and sessions are reset. **It must be deleted and its secrets revoked.**

7. MITRE ATT&CK — Techniques (Under Investigation)

TACTIC	TECHNIQUE	ID	EVIDENCE IN THIS INCIDENT
Initial Access	Phishing: Spearphishing Link	T1566.002	Lure from kijog@mngenvmcap887313, AiTM link delivered 01:57
Reconnaissance	Phishing for Information	T1598	AiTM credential-harvest proxy
Credential Access	Adversary-in-the-Middle	T1557	Session-cookie + credential theft (MFA bypass)
Credential Access	Steal Web Session Cookie	T1539	Session 004fae8a-... reused from Tor
Credential Access	Brute Force	T1110	Flagged on malicious AiTM sign-in detector
Initial Access / Persistence	Valid Accounts: Cloud	T1078.004	Interactive sign-in as Elvia from Tor; federation reach
Persistence	Account Manipulation (OAuth app/consent)	T1098	AI-Sys-AutoNinja registered + consented
Defense Evasion	Impair Defenses	T1562	Copilot jailbreak attempt (Prompt Shields)
Command & Control	Proxy: Multi-hop (Tor)	T1090.003	Tor exit nodes incl. IPv6
Collection	Data from Information Repositories	T1213	Copilot/OneDrive content access; DLP match
Exfiltration	(DLP-detected egress attempt)	T1567*	DLP "Restrict copilot by label" trigger

AI / LLM-specific behaviours (emerging TTPs)

- **LLM Reconnaissance** against gpt-4o model.
- **Jailbreak / Prompt-injection** attempts (blocked by Prompt Shields).
- **Malicious-URL injection** in prompt (<http://absoluteprintgroup.com/track>).
- **Anonymised access** to Azure AI resources from Tor.

8. IOC & Threat-Intel Confirmation

All five attacker IPs were checked against ThreatIntelIndicators. Every one is an **active, non-revoked, Confidence-100** indicator from **Microsoft Defender Threat Intelligence** (ObservableKey: network-traffic:src_ref.value).

INDICATOR	TYPE	TI STATUS	CONF.	VALID WINDOW
192.42.116.56	IPv4 / Tor / AiTM	Active, not revoked	100	2026-04-09 → 05-16
192.42.116.55	IPv4 / Tor	Active, not revoked	100	2026-04-11 → 05-09
185.220.100.243	IPv4 / Tor	Active, not revoked	100	2026-03-13 → 05-27
185.243.218.233	IPv4 / Tor	Active, not revoked	100	2026-03-14 → 05-01
185.241.208.136	IPv4 / Tor	Active, not revoked	100	2026-05-04

Full indicator set for blocking / hunting

CATEGORY	INDICATORS
Attacker IPv4	192.42.116.56, 192.42.116.55, 185.220.100.243, 185.243.218.233, 185.241.208.136
Attacker IPv6 (Tor)	2603:1026:c0a:2032::5, 2001:67c:e60:c0c:192:42:116:113, 2a07:e042:1:181::1, 2001:67c:e60:c0c:192:42:116:61, 2a0d:bbc7::f816:3eff:fe5d:4413
AiTM landing URL	https://qc2223672.victoriousfield-3d105967.northeurope.azurecontainerapps.io/
Malicious prompt URL	http://absoluteprintgroup.com/track
Phishing sender	kijog@mngenvmcap887313.onmicrosoft.com (IPv6 2a01:111:f403:c105::1)
NetworkMessageId (delivered phish)	e80ef13c-6fe8-4eb3-8243-08deb7a57454
Hijacked session	004fae8a-800d-8b3c-4b8a-18e30fc43385
Malicious OAuth app	AI-Sys-AutoNinja - appId 8cfa5715-1f9e-4d2f-8c5b-81a59c37cd80 (objectId ae8b5dc2-b985-4d10-9cd2-feec9726a9f9)
Abused Azure resource	mdc-d4ai-aoai-1 (sub 4fc2c46b-4b55-49c7-9621-730e0a08c4aa, RG MDC-D4AI)

9. Patient Zero — Source of the Attack

Conclusion

The intrusion originates from a **spearphishing email** sent by `kijog@mngenvmcap887313.onmicrosoft.com` — a throwaway Microsoft trial tenant (MngEnvMCAP887313). An initial copy was quarantined at 01:31, but a second copy was **delivered to Elvia's Inbox at 01:57:53** (`networkMessageId e80ef13c- ...`). That single message is patient zero.

Kill-chain from patient zero

#	STAGE	DETAIL
1	Lure delivered	01:57:53 - "[URGENT] [System Name] Outage" reaches Inbox (3 URLs)
2	User clicks AiTM link	02:15-02:44, 7x ClickAllowed to <code>qc2223672.victoriousfield- ... azurecontainerapps.io</code>
3	Credential + cookie proxied	AiTM reverse proxy captures auth and session cookie (MFA defeated)
4	Attacker sign-in	~02:47 from 192.42.116.56 (Amsterdam Tor), session 004fae8a-...
5	AI abuse + persistence	Copilot/Azure OpenAI abuse 02:49-04:05; OAuth app consented 04:15

Why it landed: the AiTM URL is hosted on a legitimate `azurecontainerapps.io` sub-domain, which Safe Links rated **Allowed** — trusted-cloud-hosting evasion. The expense-report follow-ups (02:21-02:38) were reinforcement, but the 01:57 outage lure is the confirmed entry point.

10. Recommendations

Contain now (P1)

- **Delete OAuth app AI-Sys-AutoNinja** (appId 8cfa5715-1f9e-4d2f-8c5b-81a59c37cd80) and revoke all its secrets/SP. This is the open persistence.
- **Re-revoke Elvia's sessions** and reset her password **after** the app is removed; re-disable until validated.
- **Re-run the failed playbooks** (Block-EntraIDUser, AWSIAM-DeleteAccessKeys) with valid tokens; rotate any AWS IAM keys mapped to the identity.
- **Block** the 5 attacker IPs + AiTM domain + `absoluteprintgroup.com` at the edge / in TI.

Eradicate & verify (P2)

- Audit consented permissions/scopes on AI-Sys-AutoNinja before deletion to scope what it could reach.
- Review GCP / AWS / Zava GSOC federation logs for any use of Elvia's federated identity on 22 May+.
- Purge remaining phishing copies (the expense-report lures) from the mailbox; tenant-wide hunt for the sender domain.
- Review Azure OpenAI `mdc-d4ai-aoai-1` logs for prompts/outputs that may have leaked data.

Harden (P3)

- Enforce **phishing-resistant MFA** (FIDO2 / device-bound passkeys) for critical assets to neutralise AiTM cookie theft.
- Enable **token-protection / continuous access evaluation** so stolen cookies fail outside the original device.
- Restrict **user OAuth app registration & consent** (admin consent workflow) to block the persistence path.
- Tune Safe Links to treat newly-seen `*.azurecontainerapps.io` sub-domains as untrusted.
- **Process fix:** require persistence-hunt (OAuth apps, MFA methods, inbox rules) **before** re-enabling a compromised account.

Scope note: the original request referenced `lydiab@zava-corp.com / lydiab-pc`, but incident **81192** concerns `elviala@zava-corp.com`. This report follows the actual incident entity. No device (endpoint) entity is associated with 81192 — it is a cloud-identity intrusion, so no host-forensics section applies.